МИНОБРНАУКИ РОССИИ

Федеральное государственное бюджетное образовательное учреждение высшего образования
«МИРЭА – Российский технологический университет»
РТУ МИРЭА

Институт информационных технологий (ИИТ)
Кафедра информационных технологий в атомной энергетике (ИТАЭ)

ОТЧЕТ ПО ПРАКТИЧЕСКОЙ РАБОТЕ 15

по дисциплине «Автоматизированные системы управления элементами промышленных и административных объектов»

АСУ П по подбору и продаже мультимедиа контента

Студент группы *ИКБО-50-23, Враженко Д.О.* _____
(подпись)

Преподаватель *Щербаков К.В.*

_____
(подпись)

Отчет представлен «___»_____202__г.

Москва 2026 г.

1. Анализ угроз безопасности передачи информации в сети проектируемой АСУ

Согласно архитектуре АСУ информационное взаимодействие осуществляется по следующим каналам:

- взаимодействие внешних пользователей с веб-интерфейсом через сеть Интернет;
- обмен данными между микросервисами (FastAPI, Elasticsearch, PostgreSQL, NLP-модуль) внутри центра обработки данных;
- обращение модуля внешнего поиска к API партнёрских платформ по сети Интернет;
- удалённое администрирование и мониторинг компонентов системы администратором нейросети и техническим персоналом.

На основе модели угроз и нефункциональных требований выделены следующие актуальные угрозы безопасности передаваемой информации:

- перехват трафика (сниффинг) – пассивный перехват данных при передаче по незащищённым каналам на уровне провайдера или локальной сети. Актуально для пользовательских сессий и межсервисного обмена;
- атака «Человек посередине» – активный перехват с возможностью модификации трафика. Например, подмена сертификата веб-сервера, перехват сессионных cookie;
- несанкционированный доступ к сетевым ресурсам – попытки прямого подключения к портам СУБД, поискового движка или файлового хранилища в обход прикладной логики;
- утечка данных при взаимодействии с внешними API – передача конфиденциальных параметров запроса или API-ключей в открытом виде к внешним источникам контента;
- компрометация канала управления – перехват учётных данных администратора или управляющих команд при удалённом администрировании (SSH, Kubernetes API);

- внутренние атаки типа «Восток-Запад» – распространение вредоносного трафика между микросервисами внутри ЦОД после компрометации одного из контейнеров.

2. Требования к средствам защиты передачи данных

С учётом выделенных угроз, нормативных документов (ФЗ №152 «О персональных данных», ГОСТ 34.10-2018, приказы ФСТЭК) и нефункциональных требований к системе, средства защиты должны обеспечивать:

- шифрование и аутентификацию всех внешних клиент-серверных соединений;
- организацию защищённых туннелей для удалённого администрирования и связи между распределёнными сегментами;
- взаимную аутентификацию и шифрование трафика между микросервисами внутри ЦОД;
- фильтрацию и контроль трафика на периметре сети с функциями предотвращения вторжений;
- защищённое хранение и передачу ключевой информации и паролей;
- соответствие требованиям по локализации персональных данных и сертификации средств криптозащиты при использовании на территории РФ.

3. Сравнительный анализ существующих средств обеспечения безопасности передачи информации

В таблице 1 представлены основные классы средств защиты передачи данных и их представители, релевантные для проектируемой АСУ.

Таблица 1 - Сравнение средств защиты передачи данных

Критерий / Средство	**TLS 1.3 / HTTPS**	**WireGuard VPN**	**IPsec (StrongSwan)**	**Istio Service Mesh (mTLS)**	**NGFW (UserGate, ViPNet)**
Уровень модели OSI	Транспортный / Прикладной	Сетевой (L3)	Сетевой (L3)	Прикладной (L7)	L3-L7
Основное назначение	Защита веб-трафика клиент-сервер	Простое высокопроизводительное туннелирование	Универсальное туннелирование и site-to-site	Взаимная аутентификация и шифрование сервисов в K8s	Защита периметра, межсетевое экранирование, IPS/IDS, VPN
Криптостойкость	AES-256-GCM, ChaCha20-Poly1305, ECDHE	ChaCha20-Poly1305, Curve25519	AES-256-GCM, IKEv2	Автоматическая ротация сертификатов, AES-GCM	Зависит от реализации VPN (обычно IPsec, OpenVPN)
Производительность	Небольшие накладные расходы на CPU	Очень высокая, минимальные задержки	Средняя, может требовать аппаратного ускорения	Доп. задержка из-за sidecar-прокси (Envoy)	Высокая (специализированное железо/ПО)
Удобство управления	Простота (настройка веб-сервера)	Простота (конфигурация в несколько строк)	Сложность (настройка политик IKE, маршрутизации)	Высокое (декларативная конфигурация, интеграция с K8s)	Наличие единой консоли, централизованный аудит
Сертификация ФСТЭК	СКЗИ класса КС1/КС2 в составе ПО	Не сертифицирован как самостоятельное СКЗИ	Сертифицирован в составе СКЗИ	Не применимо (инфраструктурный слой)	Полная сертификация всего устройства

4. Выбор и обоснование комплекса средств защиты

На основе архитектуры проектируемой АСУ и сравнительного анализа, для обеспечения безопасности передачи информации предлагается эшелонированный подход, включающий следующие средства:

1. TLS 1.3 / HTTPS – основной протокол защиты взаимодействия пользователей с веб-интерфейсом системы через Интернет. Обеспечивает конфиденциальность и целостность сессии, предотвращает перехват и MitM-атаки. SSL-терминация выполняется на Nginx-балансировщике, согласно выбранной архитектуре.
2. Межсетевой экран нового поколения с функциями VPN – выбран в качестве аппаратно-программной платформы для защиты периметра ЦОД. Обеспечивает:
   - фильтрацию входящего и исходящего трафика (Firewall);
   - обнаружение и предотвращение сетевых атак (IPS/IDS);
   - организацию защищённого удалённого доступа (VPN) для администратора нейросети и контент-менеджеров по протоколу IPsec или ViPNet-туннелю, что сертифицировано ФСТЭК и удовлетворяет требованиям по защите ПДн.
3. Istio Service Mesh (mTLS) – для защиты межсервисного трафика внутри кластера Kubernetes. Принудительное использование mutual TLS гарантирует, что все вызовы между модулями FastAPI, NLP-сервисом и Elasticsearch шифруются, а сервисы взаимно аутентифицируются, что полностью нейтрализует угрозу типа «Восток-Запад» и предотвращает несанкционированный доступ к базам данных в обход API.
4. WireGuard – легковесный VPN для быстрого и безопасного соединения с сервером резервного копирования или внешним хранилищем данных (S3), если они территориально удалены.

5. Протокол SSHv2 – для защищённого консольного администрирования серверных операционных систем, используемый только из изолированного сегмента управления.

5. Описание возможностей выбранных средств с учётом угроз

5.1. TLS 1.3 / HTTPS

Нейтрализуемая угроза: пассивный перехват, MitM.

Возможности: шифрование всего трафика между браузером пользователя и точкой входа; использование стойких шифронаборов, эфемерных ключей Диффи-Хеллмана для обеспечения прямой секретности; применение сертификатов, выпущенных доверенным центром, предотвращает подмену сервера.

5.2. NGFW (ViPNet Coordinator HW)

Нейтрализуемая угроза: сетевые атаки, сканирование портов, несанкционированный доступ извне, утечка данных при администрировании.

Возможности: осуществляет глубокий анализ пакетов, блокирует попытки эксплуатации уязвимостей на периметре; создаёт криптографически защищённый туннель между рабочей станцией администратора и внутренней сетью ЦОД, обеспечивая конфиденциальность и аутентификацию управляющих команд; ведёт централизованный лог событий безопасности, служит точкой аудита.

5.3. Istio Service Mesh (mTLS)

Нейтрализуемая угроза: несанкционированный доступ к внутренним сервисам, подмена сервиса, прослушивание внутреннего трафика.

Возможности: автоматически внедряет sidecar-прокси к каждому поду, который прозрачно шифрует весь TCP-трафик между микросервисами; использует собственный центр сертификации (Citadel) для выдачи и ротации краткоживущих сертификатов X.509 каждому сервису; политики авторизации позволяют ограничить, например, прямой доступ к PostgreSQL только от

сервиса авторизации, блокируя любые другие соединения, даже изнутри кластера.

5.4. WireGuard

Нейтрализуемая угроза: перехват резервных копий или трафика синхронизации между ЦОД.

Возможности: обеспечивает высокопроизводительное шифрованное соединение точка-точка с аутентификацией на основе открытых ключей; простота конфигурации и минимальная поверхность атаки благодаря малому объёму кода.